

Procédure d'audit web avec OWASP ZAP

Détection — Remédiation — Vérification | Exercice 2A, Chapitre 4 (Attaques Web)

Auteur : CHERY Jean-Hadley — Lab SOC personnel | **Date** : 20 juillet 2026

Outil : OWASP ZAP 2.17.0 (scan passif) | **Cible** : <https://portfolio-soc-six.vercel.app> (site personnel, autorisé)

1. Objectif

Auditer une application web réelle avec OWASP ZAP : détecter les vulnérabilités, les corriger, puis re-tester pour prouver la correction. Document conçu comme une **procédure reproductible** — chaque commande est indiquée avec sa machine, son terminal et son résultat.

2. Environnement

Élément	Détail
Machine attaquante	Kali Linux (VM) — terminal Kali (invite kali@kali)
Poste d'administration	Windows 11 ESHU — terminal PowerShell
Cible	Portfolio statique React/Vite hébergé sur Vercel
Code source du site	C:\Users\ESHU\portfolio-soc\
Dépôt Git	github.com/J-Hadley-C/portfolio-soc (branche master)

3. PROCÉDURE — Phase 1 : détection

Étape 1 — Vérifier si ZAP est installé

Terminal : Kali

```
which zaproxy
```

Rôle : which cherche le chemin de l'exécutable. Résultat : aucune sortie → ZAP non installé.

Étape 2 — Installer ZAP

Terminal : Kali

```
sudo apt update && sudo apt install -y zaproxy
```

Rôle : apt update rafraîchit la liste des paquets ; && enchaîne si succès ; apt install -y zaproxy installe sans confirmation.

Étape 3 — Lancer ZAP

Terminal : Kali

```
zaproxy &
```

Rôle : lance l'interface graphique ; le & la met en arrière-plan. Au démarrage, choisir No, I do not want to persist this session .

Étape 4 — Définir le périmètre et lancer le scan passif (interface ZAP)

Principe du **scan passif** : ZAP se place en proxy entre le navigateur et le site et **observe** le trafic, sans envoyer d'attaque.

1) Onglet **Quick Start** → **Manual Explore**. 2) Champ **URL to explore** : <https://portfolio-soc-six.vercel.app>. 3) Cocher **Enable HUD** → **Launch Browser**. 4) Naviguer sur les pages **du site uniquement**.

Règle de périmètre (essentielle) : ne PAS suivre les liens sortants (LinkedIn, GitHub, e-mail). Un scan passif suit tout le trafic ; cliquer ces liens ferait analyser des sites tiers hors périmètre.

Étape 5 — Lire les résultats (interface ZAP)

Panneau du bas → onglet **Alerts**. Couleurs : rouge = High, orange = Medium, jaune = Low, bleu = Info. **Résultat initial** : **16 alertes, 0 grave** — en majorité des en-têtes de sécurité HTTP manquants.

4. Vulnérabilités détectées (scan initial)

Vulnérabilité	Gravité	Impact
CSP Not Set	Moyen	Pas de liste blanche → injection de scripts possible
Missing Anti-clickjacking Header	Moyen	Site piégeable dans une iframe (clickjacking)
Mauvaise configuration CORS (Allow-Origin: *)	Moyen	Lecture cross-origin possible
Strict-Transport-Security (HSTS) Not Set	Faible	HTTPS non imposé
X-Content-Type-Options Missing	Faible	MIME sniffing possible
Server Leaks X-Powered-By	Faible	Techno serveur révélée
Server Leaks Version (Server)	Faible	Version serveur révélée
Sub Resource Integrity Missing	Faible	Ressources externes non vérifiées
Cookie No HttpOnly / no SameSite	Faible	Cookies mal configurés
Private IP Disclosure	Faible	IP privée exposée
Suspicious Comments / constats divers	Info	Pas des failles

5. PROCÉDURE — Phase 2 : remédiation

Principe : ajouter les en-têtes de sécurité manquants à toutes les réponses du serveur, via le fichier `vercel.json` du projet.

Étape 6 — Éditer le fichier `vercel.json`

Fichier : `C:\Users\ESHU\portfolio-soc\vercel.json` — contenu complet appliqué :

```
{
  "rewrites": [{ "source": "/(.*)", "destination": "/index.html" }],
  "headers": [
    {
      "source": "/(.*)",
      "headers": [
        {
          "key": "Content-Security-Policy",
          "value": "default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data:; connect-src 'self' https://formspree.io; form-action 'self' https://formspree.io; frame-ancestors 'none'; base-uri 'self'; object-src 'none'"
        },
        { "key": "X-Frame-Options", "value": "DENY" },
        { "key": "Strict-Transport-Security", "value": "max-age=63072000; includeSubDomains; preload" },
        { "key": "X-Content-Type-Options", "value": "nosniff" },
        { "key": "Referrer-Policy", "value": "strict-origin-when-cross-origin" },
        { "key": "Permissions-Policy", "value": "geolocation=(), microphone=(), camera=()" }
      ]
    }
  ]
}
```

Le CSP est **adapté au site** : il autorise Google Fonts et l'envoi du formulaire vers Formspree, sinon l'affichage casserait.

Étape 7 — Déployer la correction

Terminal : PowerShell Windows

```
cd C:\Users\ESHU\portfolio-soc
git add vercel.json
git commit -m "Ajoute des en-tetes de securite HTTP (audit OWASP ZAP)"
git push
```

Rôle : cd se place dans le projet ; git add prépare le fichier ; git commit l'enregistre ; git push l'envoi sur GitHub. **Vercel redéploie automatiquement** (~1-2 min).

Étape 8 — Vérifier les en-têtes en ligne

Terminal : PowerShell Windows

```
$r = Invoke-WebRequest -Uri "https://portfolio-soc-six.vercel.app" -Method Head -UseBasicParsing
$r.Headers.GetEnumerator() | Where-Object { $_.Key -match "Content-Security|X-Frame|Strict-Transport|X-Content-Type|Referrer|Permissions" } |
Format-Table -AutoSize -Wrap
```

Rôle : -Method Head récupère seulement les en-têtes ; le filtre n'affiche que ceux de sécurité. Résultat : les **6 en-têtes présents**.

Étape 9 — Re-scanner pour prouver la correction (interface ZAP)

1) ZAP → **Fichier** → **Nouvelle session** (alertes remises à 0). 2) **Manual Explore** → même URL → **Launch Browser**. 3) Ctrl+Maj+R (rechargement sans cache), naviguer sur le site uniquement. 4) Onglet **Alerts**.

Résultat du second scan : 9 alertes, 0 grave (3 Moyen · 2 Faible · 4 Info). Les alertes anti-clickjacking, MIME sniffing et fuites de version ont disparu.

6. Correspondance vulnérabilité → correction

Vulnérabilité initiale	Correction appliquée	Statut
CSP Not Set	En-tête Content-Security-Policy (adapté)	Corrigé
Anti-clickjacking manquant	X-Frame-Options: DENY + frame-ancestors none	Corrigé
HSTS Not Set	En-tête Strict-Transport-Security	Corrigé (vérifié)
X-Content-Type-Options	En-tête X-Content-Type-Options: nosniff	Corrigé
Fuite de provenance	En-tête Referrer-Policy	Corrigé
Fonctions navigateur inutiles	En-tête Permissions-Policy	Corrigé
Server / X-Powered-By	—	Non corrigeable (infra Vercel)
CSP style-src unsafe-inline	Requis par React/Framer Motion	Compromis assumé
CORS Allow-Origin: *	Sans risque sur site statique	Accepté
Sub Resource Integrity	Améliorable (URL Google changeantes)	Mineur
Private IP Disclosure	À investiguer (souvent faux positif)	Mineur
Suspicious Comments / constats	Faux positifs / informationnels	Aucun risque

Bilan : 6 vulnérabilités corrigées et vérifiées, 2 non corrigeables (limite hébergeur), 9 alertes résiduelles dont aucune exploitable.

7. Pièges rencontrés et leçons d'analyste

- 1. Périmètre (scope).** Un scan passif suit les liens sortants : en cliquant les icônes LinkedIn/GitHub, ZAP a analysé ces sites tiers et remonté une faille High sur une librairie de LinkedIn (DOMPurify 2.3.5, CVE-2024-47875) — hors périmètre, écartée.
- 2. URL mal saisie.** Une frappe http// (sans deux-points) crée un faux domaine parasite dans ZAP et fausse les alertes. Vérifier l'URL et repartir d'une session propre.
- 3. Cache CDN.** Des réponses en cache peuvent afficher un état périmé des en-têtes. Vérifier l'état réel du serveur (Étape 8) plutôt que le seul affichage de ZAP.
- 4. Trier le réel du bruit.** La valeur d'un audit n'est pas de tout corriger mais de qualifier chaque alerte : risque réel, compromis, faux positif ou constat.
- 5. Détecter → corriger → re-tester.** Le cycle complet transforme un scan en démarche de sécurisation prouvée.

8. Conclusion

Audit passif mené de bout en bout sur une application web réelle : 16 faiblesses détectées, 6 en-têtes de sécurité ajoutés via vercel.json et vérifiés sur le serveur, second scan à 9 alertes dont 0 exploitable. Le portfolio présente désormais une posture de sécurité web renforcée, conforme aux bonnes pratiques OWASP sur les en-têtes HTTP.